PROJECT 5

Risk Assessment & Register

Calculate real risk metrics (ALE, SLE, ARO) and recommend treatment strategies for a fictional company

Your Name:	**Date:**
Tyler Arend	**9/18/2026**

What is this project?

Risk managers help organizations understand what could go wrong and how much it could cost. They use math formulas to calculate expected losses — then decide how to treat each risk. In this project, you will analyze 5 real security risks for a fictional e-commerce company, calculate the financial impact of each using ALE formulas, and recommend a treatment strategy. You will also write a short Risk Summary for company leadership.

Part 1: The Formulas (Reference This All Project)

These three formulas are all you need. They will appear on the Security+ exam.

SLE	ARO	ALE
Single Loss Expectancy **SLE = Asset Value x Exposure Factor** *How much ONE incident costs*	Annualized Rate of Occurrence **How often per year (estimate)** *e.g., once every 5 yrs = 0.2*	Annualized Loss Expectancy **ALE = SLE x ARO** *Expected cost PER YEAR*

Worked Example - Follow this model:

SCENARIO: PixelShop has a web server worth $50,000.
A DDoS attack could take it completely offline (Exposure Factor = 100% = 1.0).
Based on industry data, this happens roughly once every 2 years (ARO = 0.5).

CALCULATION:
SLE = $50,000 x 1.0 = $50,000 (one incident costs $50,000)
ALE = $50,000 x 0.5 = $25,000 (expected loss per year = $25,000)

TREATMENT: Since a DDoS mitigation service costs $8,000/year, MITIGATING makes financial sense
because $8,000 < $25,000. If the mitigation cost $30,000/year, we might ACCEPT the risk instead.

KEY INSIGHT: If the cost to fix a risk is MORE than the ALE, it may make sense to Accept the risk!

Part 2: Your Scenario

COMPANY: PixelShop Online Retail

PixelShop is a mid-sized e-commerce company selling electronics online. Annual revenue: $5 million.

Key assets:

- Customer database: 200,000 records including names, emails, addresses, and payment info (Value: $400,000)
- E-commerce web server: processes all orders and transactions (Value: $80,000)
- Company laptops: 45 employee laptops used for work (Value: $90,000 total / ~$2,000 each)
- Internal file server: contains financial records, supplier contracts, product designs (Value: $150,000)
- Payment processing system: handles credit card transactions (Value: $200,000)

Part 3: The Risk Register

Complete the risk register for all 5 risks below. Use the formulas from Part 1.

Asset Values and Exposure Factors are provided for you. You need to estimate ARO and calculate ALE.

Risk Name	Threat Vector	Asset Value ($)	Exposure Factor	SLE ($) = AV x EF	ARO (YOU ESTIMATE)	ALE ($) = SLE x ARO	Treatment Strategy
Phishing attack leads to ransomware on employee laptops	Phishing email with malicious attachment	**$90,000**	**0.50 (50%)**	**$45,000** *(already done!)*	*Estimate: **3.0***	*Calculate: $**135,000***	*Avoid / Transfer / Mitigate / Accept*
Data breach of customer database	SQL injection attack on web application	**$400,000**	**0.30 (30%)**	*Calculate: $**120,000***	*Estimate: **0.5***	*Calculate: $**60,000***	*Avoid / Transfer / Mitigate / Accept*

Web server DDoS attack causes outage	Volumetric DDoS from botnet	**$80,000**	**1.0 (100%)**	*Calculate: $**80,000***	*Estimate : **0.5***	*Calculate: $**40,000***	*Avoid / Transfer / Mitigate / Accept*
Insider threat leaks financial files	Disgruntled employee with file server access	**$150,000**	**0.20 (20%)**	*Calculate: $**30,000***	*Estimate : **0.1***	*Calculate: $**3,000***	*Avoid / Transfer / Mitigate / Accept*
Payment system breach exposes card data	Unpatched payment API vulnerability	**$200,000**	**0.75 (75%)**	*Calculate: $**150,000***	*Estimate : **0.5***	*Calculate: $**75,000***	*Avoid / Transfer / Mitigate / Accept*

ARO Estimation Guide (for the ARO column above):

ARO = how many times per year, on average, this risk could occur

Once per year = 1.0 | Once every 2 years = 0.5

Once every 5 years = 0.2 | Once every 10 years = 0.1

Twice per year = 2.0 | Rarely (1 in 20 yrs) = 0.05

Use industry knowledge + common sense. There is no single correct answer.

e.g., phishing attacks on a company happen frequently - perhaps 2-3x per year (ARO = 2.0 or 3.0)

Part 4: Analysis Questions

Which risk has the highest ALE? What does that tell us about where to focus security spending?

The risk with the highest ALE is "Phishing attack leads to ransomware on employee laptops", with a value of $135,000. This shows the real damage of phishing attacks, as well as malware like ransomware, and the importance of employee training on spotting these attacks.

For each treatment strategy you chose (Avoid, Transfer, Mitigate, Accept), explain your reasoning for at least 2 of them.

1. *I chose "Avoid" for "Data breach of customer database" because of the attack vector "SQL injection attack on web application". A web application can be configured to not allow SQL commands, therefore solving the problem.*
2. *I chose "Mitigate" for "Web server DDoS attack causes outage" because this issue may not be able to be solved completely, but it can be reduced in severity by having more than one web server to handle increased traffic.*

Residual Risk: After applying your recommended treatments, what risk still remains?	**What is the total estimated ALE across all 5 risks combined?**
Even after applying the recommended fixes, many of these issues cannot be solved completely. For example, there will always be the risk of an employee falling for a phishing scam; new employees joining the company or rapidly evolving phishing scams will always pose a threat to the company, even with training in place. *The following risks will still remain: phishing attacks, DDoS attacks and insider threats. By securing the web application against SQL injections and patching the API vulnerability, these threats should be eliminated.* *Source:* *Mitigate Risk: When to Avoid, Transfer, or Accept?*	Add all 5 ALE values: $***313,000*** *The total revenue after the total ALE value is subtracted is $4,687,000. While the total ALE seems large, the total revenue is still a positive number and still in the millions. However, PixelShop can still grow, and the total ALE value will also continue to grow.*

Part 5: Risk Summary for Leadership

Write a short summary (5-8 sentences) that explains your findings to PixelShop's CEO.

Use plain language. Avoid jargon. Your goal is to help them understand where their money is at risk and what to do about it.

Risk Summary (write 5-8 sentences):
After analyzing PixelShop's key assets and security risks, I identified five areas of concern that cost the company $313,000 annually. The most significant risk, accounting for $135,000 in annual loss, is phishing attacks against employees. To mitigate this risk, cybersecurity training with a focus on malware and phishing attacks for all employees is recommended. The second risk to the company, accounting for $75,000 in annual loss, is an unpatched payment API vulnerability that may expose customer card data when breached. To avoid this risk, patching this API vulnerability as soon as possible is recommended. The third risk to the company, accounting for $60,000 in annual loss, is an unsecure web application that may expose customer data during a breach. To avoid this risk, the web application should be secured by not allowing SQL commands in any user input elements as soon as possible. The fourth risk to the company, accounting for $40,000 in annual loss, is outages to the web server during DDoS attacks. To mitigate this risk, the web server should be scaled appropriately to the volume of web traffic being received, allowing employees to continue using web services during these attacks. Finally, the fifth risk to the company, accounting for $3,000 in annual loss, is internal threats. This threat may always be possible, but can be managed by frequent review of employee permissions, not allowing them access to systems they don't need for their work tasks.

Reflection

What surprised you most about the numbers?	How does this connect to what you learned about GRC in class?
I was most surprised by the cost of phishing attacks for companies. While I expected a bigger number, I was not expecting it to be the biggest costing issue.	*Managing risks is why frameworks, policies, and regulatory requirements exist in cyberspace. Acknowledging these costs and their impact on companies, employees, and customers allows us to create strategies to avoid or limit their damage.*

Before You Submit: Checklist

Check each item when complete:

- [✔] I completed the Risk Register (all 5 risks, all columns filled in)
- [✔] I showed my SLE calculations (AV x EF) for all 5 risks
- [✔] I estimated ARO for all 5 risks and explained my reasoning
- [✔] I calculated ALE (SLE x ARO) for all 5 risks
- [✔] I chose a treatment strategy for each risk
- [✔] I answered all 3 analysis questions
- [✔] I wrote the executive summary (5-8 sentences)

Portfolio tip: Title this: 'Risk Assessment Report - PixelShop - [Your Name]'
Talking point: 'I performed a quantitative risk analysis calculating SLE, ARO, and ALE for 5 cybersecurity risks, and recommended treatment strategies based on financial impact.'